

Risk Scoring Report — vulnerable-invoice-service

Project: com.demo.supplychain:vulnerable-invoice-service:1.0.0 · Generated: 2026-06-11 · Source SHA: 72fe788e · Model: 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality

Executive Summary

Band	Count
HIGH	4
MEDIUM	3
LOW	8
Total ranked	15

Outdated dependencies: 8 of 17 · License violations: 1 (GPL-2.0) · Supply-chain alerts: 2 (typosquatted coord + untrusted HTTP mirror) · Total CVE instances: 31 (across 7 affected packages; 54 in jackson-databind alone)

Ranked Remediation Backlog

Rank	Coordinate	Risk Score	Band	Top CVE	CVSS	Total CVEs	Fix Version
1	jackson-databind:2.9.8	7.8	HIGH	CVE-2019-14379	9.8	54	2.14.0
2	log4j-api:2.14.1	7.8	HIGH	CVE-2021-44228	10.0	5	2.17.1
3	log4j-core:2.14.1	7.8	HIGH	CVE-2021-44228	10.0	8	2.17.1
4	mysql-connector-java:8.0.30	6.3	HIGH	CVE-2022-21363	6.6	3	8.0.31
5	guava:24.1.1-jre	5.5	MEDIUM	CVE-2023-2976	5.5	2	32.0.0-jre
6	commons-lang3:3.4	5.2	MEDIUM	CVE-2025-48924	5.3	1	3.20.0
7	commons-io:2.4	4.7	MEDIUM	CVE-2024-47554	4.3	1	2.14.0
8–15	Transitive deps (no CVEs)	1.9–2.2	LOW	—	—	0	—

Component Scores (top 7)

Dependency	CVE Severity	Exposure	Business Criticality	Risk Score	Band
jackson-databind 2.9.8	10.0	8.0	2.0	7.8	HIGH
log4j-api 2.14.1	10.0	8.0	2.0	7.8	HIGH
log4j-core 2.14.1	10.0	8.0	2.0	7.8	HIGH
mysql-connector-java 8.0.30	7.0	7.0	2.0	6.3	HIGH
guava 24.1.1-jre	5.5	7.0	2.0	5.5	MEDIUM
commons-lang3 3.4	5.3	7.0	2.0	5.2	MEDIUM

commons-io 2.4	4.3	7.0	2.0	4.7	MEDIUM
----------------	-----	-----	-----	-----	--------

Top Findings Detail

jackson-databind 2.9.8 — Rank 1 · Score 7.8 · HIGH

Direct compile dependency carrying **54 CVEs** including 6 CRITICAL deserialization gadget-chain vulnerabilities (CVE-2019-14379, CVE-2019-14540, CVE-2019-16335, CVE-2019-16942, CVE-2019-16943, CVE-2019-17267 — all CVSS 9.8). Attackers supplying crafted JSON can achieve remote code execution. CVE severity density-capped to 10.0.

Fix: Upgrade to `2.22.0` (latest stable). Minimum: `2.14.0`.

log4j-core 2.14.1 — Rank 3 · Score 7.8 · HIGH

Log4Shell (CVE-2021-44228, CVSS 10.0) — unauthenticated RCE via JNDI lookup in log message strings. Directly imported in `DiscountCalculator.java`. Also carries CVE-2021-45046 (CVSS 9.0) and 2026 high-severity CVEs. One of the most broadly exploited vulnerabilities in recorded history.

Fix: Upgrade both `log4j-api` and `log4j-core` to `2.17.1`. Plan upgrade to `3.0.0` for 2026 CVEs.

mysql-connector-java 8.0.30 — Rank 4 · Score 6.3 · HIGH

3 medium CVEs (max 6.6) plus a **GPL-2.0 license violation** in a project declared permissive-only. CVE-2022-21363 allows authenticated attackers with high-privilege server access to read/write arbitrary files.

Fix: Upgrade to `8.0.33`. Assess license compliance — consider `com.mysql:mysql-connector-j`.

Supply-Chain Alerts

Alert	Severity	Detail
Typosquatted dependency	CRITICAL	<code>com.fastxml.jackson.core:jackson-databind</code> — misspelled groupId (missing "er"). Remove immediately.
Untrusted HTTP mirror	HIGH	<code>http://insecure-mirror.example.net/maven2</code> — plain HTTP, no integrity verification. Remove or replace with HTTPS.

Priority Recommendations

- P0 — Remove typosquatted dependency** `com.fastxml.jackson.core:jackson-databind` from `pom.xml`.
- P0 — Upgrade log4j** `2.14.1` → `2.17.1` (Log4Shell; actively exploited in the wild).
- P1 — Upgrade jackson-databind** `2.9.8` → `2.22.0` (54 CVEs including 6 CRITICAL RCE).
- P1 — Remove untrusted HTTP mirror** from `pom.xml` repositories block.
- P2 — Upgrade mysql-connector-java** `8.0.30` → `8.0.33`; resolve GPL-2.0 license issue.
- P3 — Upgrade guava** `24.1.1-jre` → `32.0.0-jre` (2 CVEs, major version — test API compatibility).
- P3 — Upgrade commons-lang3** `3.4` → `3.20.0` and **commons-io** `2.4` → `2.14.0`.

Scoring Methodology

`risk_score = round( 0.5 × cve_severity + 0.3 × exposure + 0.2 × business_criticality, 1 )`

CVE Severity: max CVSS base score + 0.5 per additional CVE (density bonus), capped at 10.

Exposure: direct(+4)/transitive(+2) + compile/runtime(+3)/test(+1) + multi-module(+2) + network/parsing lib(+1), capped at 10.

Business Criticality: auth/crypto/payment(+5), public API(+3), internal service(+2), build/test(+1), capped at 10. Default=2.

Band	Threshold
CRITICAL	risk_score ≥ 8.0
HIGH	6.0 – 7.9 (also: any dep with a CRITICAL CVE floored here)
MEDIUM	3.0 – 5.9
LOW	< 3.0

*Machine-readable: `depscan-risk-report.json` · Ready for **Auto-Remediation Skill (Stage 3)** and **PR Validation Agent (Stage 4)**.*